

Informe de Auditoría de Ciberseguridad - Servidor Linux

Fecha de Auditoría: 2023-10-27 Servidor Auditado (IP HASH):

70e5b445d2cd4df59835f538ba9f0b6f0d258017a4d7e070f9206bf6df480fbf Sistema Operativo: Ubuntu Server Origen de Datos: Script Python, estándar CIS Benchmarks

1. Resumen Ejecutivo

Este informe detalla los hallazgos de seguridad identificados en el servidor Ubuntu Server con el hash de IP especificado. La auditoría se centró en la gestión de cuentas de usuario y la exposición de servicios de red.

Se han detectado configuraciones que representan un **riesgo crítico** para la seguridad del sistema, principalmente la existencia de una cuenta de sistema con capacidad de inicio de sesión interactivo y la exposición de servicios clave como SSH y DNS, sin evidencia de endurecimiento de seguridad adecuado.

Score de Seguridad: 40/100 (Críticamente Bajo)

La puntuación refleja una postura de seguridad deficiente que requiere atención inmediata. La presencia de vulnerabilidades críticas puede conducir a la escalada de privilegios, acceso no autorizado al sistema y la posible utilización del servidor como plataforma para ataques adicionales.

Recomendación Urgente: Se requiere una remediación inmediata de los hallazgos críticos y de alta prioridad para mitigar la exposición del servidor a posibles ataques.

2. Hallazgos Prioritarios

Los siguientes hallazgos se presentan en orden de criticidad, de mayor a menor:

2.1. CRÍTICO: Cuenta de Sistema (UID 4) con Acceso Interactivo

Una cuenta de sistema con UID 4 (típicamente asociada a usuarios como adm o sync en sistemas Debian/Ubuntu) tiene configurado `/bin/sync` como shell y `tiene_login: true`. Si bien `/bin/sync` no es una shell interactiva estándar, el hecho de que `tiene_login: true` esté establecido sugiere una configuración errónea grave. Las cuentas de sistema no deben tener capacidad de inicio de sesión interactivo para reducir la superficie de ataque y prevenir el abuso de privilegios. Un atacante que comprometa esta cuenta podría explotar la capacidad de inicio de sesión para ejecutar comandos con los privilegios de este UID, o incluso intentar escalar privilegios si la configuración de `/bin/sync` o permisos asociados están mal gestionados.

2.2. ALTO: Exposición de Servicio SSH con Múltiples Cuentas Interactivas (Puerto 22 TCP)

El servicio SSH (Secure Shell) está expuesto en el puerto 22 TCP. Aunque SSH es un servicio esencial para la administración remota, su exposición, combinada con la existencia de múltiples cuentas con acceso interactivo (/bin/bash), incrementa significativamente el riesgo.

Correlación de Riesgos:

- **Usuario con UID 0 (/bin/bash):** Esta es la cuenta root o su equivalente. Si el acceso por contraseña para root está habilitado a través de SSH, representa un riesgo extremo de compromiso total del sistema.
- **Usuarios con UID 1000 y 1001 (/bin/bash):** Cada una de estas cuentas representa un punto de entrada potencial para ataques de fuerza bruta, adivinación de contraseñas o explotación de credenciales débiles. Un compromiso exitoso de cualquiera de estas cuentas podría llevar a una elevación de privilegios en el sistema.
- **Usuario con UID 4 (/bin/sync, tiene_login: true):** Si esta cuenta inusualmente configurada también es accesible vía SSH, se convierte en un vector de ataque directo a una cuenta de sistema.

2.3. MEDIO: Servicio DNS Expuesto (Puerto 53 TCP)

El servicio DNS (Domain Name System) está expuesto en el puerto 53 TCP. La exposición de un servidor DNS puede ser legítima, pero requiere una configuración y endurecimiento adecuados. Sin información adicional sobre su propósito (servidor recursivo para internos, autoritativo para dominios propios, etc.) y su alcance (accesible desde internet o solo red interna), representa un riesgo.

- **Correlación de Riesgos:** Un servidor DNS mal configurado o sin parches puede ser vulnerable a ataques de denegación de servicio (DDoS), envenenamiento de caché, suplantación de identidad (DNS spoofing) o puede ser explotado para fugas de información.

2.4. INFORMATIVO: Múltiples Cuentas de Usuario con Acceso Interactivo

Se han identificado cuatro cuentas de usuario con capacidad de inicio de sesión interactivo (/bin/bash o /bin/sync con tiene_login: true), incluyendo el usuario con UID 0 (root o equivalente) y dos usuarios estándar (UID 1000, 1001). Si bien es una funcionalidad normal de un servidor multiusuario, el principio de mínimo privilegio sugiere que se deben revisar todas las cuentas con acceso interactivo para asegurar que solo las necesarias lo tengan y que sus privilegios sean los mínimos indispensables para sus funciones.

3. Tabla de Riesgos

Riesgo	Impacto	Probabilidad	Severidad	Descripción
--------	---------	--------------	-----------	-------------

Acceso no autorizado a cuenta de sistema (UID 4)	Crítico: Compromiso del sistema	Alta: Configuración insegura	Crítico	La cuenta de sistema con UID 4 tiene capacidad de login interactivo (tiene_login: true), lo que puede ser explotado para obtener acceso y ejecutar comandos con privilegios elevados, violando el principio de mínimo privilegio.
Ataques de fuerza bruta / Credential Stuffing a SSH	Alto: Acceso no autorizado, elevación de privilegios	Alta: SSH expuesto + múltiples usuarios	Alto	La exposición de SSH con múltiples cuentas interactivas (incluyendo root) facilita intentos de adivinación de contraseñas. Un compromiso exitoso otorga acceso remoto al sistema, pudiendo llevar a la toma de control total.
Abuso y/o Denegación de Servicio (DoS) de DNS	Medio: Interrupción del servicio, manipulación de tráfico	Media: DNS expuesto sin contexto de seguridad	Medio	Un servidor DNS expuesto y no endurecido es vulnerable a ataques de DDoS, envenenamiento de caché, o puede ser utilizado como reflector en ataques, interrumpiendo servicios o redirigiendo tráfico maliciosamente.
Elevación de privilegios post-compromiso	Alto: Compromiso del sistema	Media: Varios puntos de entrada	Alto	Tras comprometer una cuenta de usuario estándar (UID 1000, 1001) a través de SSH, un atacante podría explotar vulnerabilidades en el sistema o configuraciones erróneas para escalar privilegios hasta obtener acceso root.

4. Recomendaciones Técnicas

Se recomienda implementar las siguientes acciones para mejorar significativamente la postura de seguridad del servidor:

4.1. Gestión de Cuentas de Usuario

Corregir la Configuración de la Cuenta con UID 4:

- **Acción:** Identificar el usuario asociado al UID 4 y cambiar su shell a `/usr/sbin/nologin` para deshabilitar el acceso interactivo.

Comandos: ```bash # 1. Identificar el nombre de usuario asociado al UID 4: grep 'x:4:' /etc/passwd`

2. Asumiendo que el usuario es 'sync' (ejemplo típico), cambiar su shell:

```
sudo usermod -s /usr/sbin/nologin sync
```

3. Verificar el cambio:

```
grep 'x:4:' /etc/passwd `` * Justificación: Las cuentas de sistema no deben tener capacidad de inicio de sesión interactivo. Esto reduce la superficie de ataque y previene el abuso de privilegios.
```

Revisar Cuenta Root (UID 0):

- **Acción:** Deshabilitar el inicio de sesión directo de root por SSH si está habilitado. Utilizar sudo para tareas administrativas desde una cuenta de usuario estándar.
- **Comando (Editar /etc/ssh/sshd_config):**

```
bash sudo sed -i 's/^PermitRootLogin yes/PermitRootLogin no/' /etc/ssh/sshd_config sudo sed -i 's/^PermitRootLogin prohibit-password/PermitRootLogin no/' /etc/ssh/sshd_config # Asegurarse de que no haya duplicados o líneas comentadas. sudo systemctl restart ssh
```
- **Justificación:** Deshabilitar el inicio de sesión directo de root por SSH es una práctica de seguridad estándar que protege la cuenta más privilegiada del sistema de ataques directos.

Implementar el Principio de Mínimo Privilegio:

- **Acción:** Auditar todas las cuentas de usuario (`grep '/bin/bash' /etc/passwd` o similar) y asegurarse de que solo los usuarios necesarios tengan acceso interactivo. Eliminar o deshabilitar cuentas innecesarias.
- **Comando (Ejemplo para deshabilitar una cuenta si no se usa):** `bash sudo usermod -L <nombre_de_usuario> # Bloquea la contraseña sudo usermod -s /usr/sbin/nologin <nombre_de_usuario> # Cambia la shell # Para eliminar si no es necesaria y no hay datos asociados críticos: # sudo userdel -r <nombre_de_usuario>`
- **Justificación:** Reducir el número de cuentas interactivas disminuye la superficie de ataque.

4.2. Endurecimiento del Servicio SSH (Puerto 22 TCP)

Configurar Autenticación Basada en Claves SSH:

- **Acción:** Deshabilitar la autenticación por contraseña y forzar el uso de claves SSH, que son más seguras.
- **Comando (Editar /etc/ssh/sshd_config):** `bash sudo sed -i 's/^PasswordAuthentication yes/PasswordAuthentication no/' /etc/ssh/sshd_config sudo systemctl restart ssh`
- **Justificación:** Las claves SSH son significativamente más robustas contra ataques de fuerza bruta que las contraseñas. **Asegúrese de que tiene acceso con clave SSH configurado y funcionando ANTES de deshabilitar la autenticación por contraseña.**

Implementar fail2ban:

- **Acción:** Instalar y configurar fail2ban para bloquear direcciones IP que intenten repetidamente iniciar sesión SSH sin éxito.
- **Comandos:** `bash sudo apt update sudo apt install fail2ban sudo systemctl enable fail2ban sudo systemctl start fail2ban` # Revisar configuración por defecto en `/etc/fail2ban/jail.conf` # y crear un archivo `/etc/fail2ban/jail.local` para personalizar.
- **Justificación:** Mitiga ataques de fuerza bruta y reduce el ruido en los logs de seguridad.

Limitar Usuarios Permitidos para SSH:

- **Acción:** Especificar explícitamente qué usuarios tienen permitido acceder al servidor vía SSH.

- **Comando (Editar /etc/ssh/sshd_config):** bash # Añadir o modificar la siguiente línea con los nombres de usuario permitidos: `echo "AllowUsers user1 user2" | sudo tee -a /etc/ssh/sshd_config` sudo systemctl restart ssh
- **Justificación:** Restringe el acceso SSH a un conjunto conocido y limitado de usuarios, reduciendo la superficie de ataque.

Cambiar el Puerto SSH (Opcional):

- **Acción:** Mover SSH a un puerto no estándar (ej. 2222) para reducir el escaneo automatizado y los intentos de ataque por defecto.
- **Comando (Editar /etc/ssh/sshd_config):** bash sudo sed -i 's/^#Port 22/Port 2222/' /etc/ssh/sshd_config # Si se cambia el puerto, actualizar la regla del firewall: # sudo ufw allow 2222/tcp sudo systemctl restart ssh
- **Justificación:** Proporciona "seguridad por oscuridad" y reduce el volumen de ataques dirigidos al puerto 22, pero no es un sustituto de la autenticación fuerte.

4.3. Endurecimiento del Servicio DNS (Puerto 53 TCP)

Evaluar Necesidad de Exposición Pública:

- **Acción:** Determinar si el servidor DNS realmente necesita ser accesible desde Internet. Si es solo para uso interno, restringir el acceso solo a las redes internas o VPN.
- **Comando (UFW para permitir solo desde IP/red específica):** bash # Borrar regla existente si permite todo el mundo al 53 sudo ufw delete allow 53/tcp # Permitir solo desde una IP específica (ej. 192.168.1.100) sudo ufw allow from 192.168.1.100 to any port 53 proto tcp # 0 desde una red específica (ej. 192.168.1.0/24) sudo ufw allow from 192.168.1.0/24 to any port 53 proto tcp sudo ufw enable # Asegurarse que UFW está activo
- **Justificación:** Limitar la accesibilidad reduce drásticamente la superficie de ataque.

Configurar para No Recursividad Externa:

- **Acción:** Si el servidor DNS es autoritativo para algunos dominios, pero no debe resolver consultas recursivas para cualquier cliente de Internet, debe configurarse para deshabilitar la recursividad para IPs externas.
- **Comando (Depende del software DNS, ej. BIND9 en /etc/bind/named.conf.options):** text # Ejemplo para BIND9 options {
... otras opciones ... allow-recursion { 127.0.0.1; 192.168.1.0/24; }; # Solo IPs internas recursion no;
0 deshabilitar recursión completamente si es solo autoritativo # ... }; sudo systemctl restart bind9

- **Justificación:** Previene el uso del servidor como un amplificador en ataques DDoS y protege contra el envenenamiento de caché desde fuentes externas.

Asegurar DNSSEC:

- **Acción:** Si el servidor DNS es autoritativo para dominios propios, implementar y configurar DNSSEC para asegurar la integridad de las respuestas DNS.
- **Justificación:** Protege contra la suplantación de identidad DNS y garantiza que los clientes reciban información DNS auténtica.

4.4. General

Mantener el Sistema Actualizado:

- **Acción:** Aplicar regularmente parches de seguridad y actualizaciones del sistema operativo y todos los paquetes instalados.
- **Comandos:** `bash sudo apt update sudo apt upgrade -y sudo apt autoremove -y # Considerar 'unattended-upgrades' para parches de seguridad automáticos. sudo apt install unattended-upgrades sudo dpkg-reconfigure --priority=low unattended-upgrades`
- **Justificación:** Las actualizaciones corrigen vulnerabilidades conocidas que podrían ser explotadas por atacantes.

Implementar un Firewall (UFW/iptables):

- **Acción:** Asegurarse de que el firewall esté configurado para permitir solo los puertos y protocolos necesarios y bloquear todo el tráfico restante por defecto.
- **Comandos (Ejemplo UFW):** `bash sudo ufw default deny incoming sudo ufw default allow outgoing sudo ufw allow ssh # 0 el puerto modificado sudo ufw allow 53/tcp sudo ufw allow 53/udp # DNS también usa UDP sudo ufw enable sudo ufw status verbose`
- **Justificación:** El firewall es la primera línea de defensa para el acceso a la red, limitando la exposición del servidor.

Auditoría y Monitoreo de Logs:

- **Acción:** Configurar un sistema centralizado de gestión de logs (SIEM) o al menos revisar regularmente los logs del sistema (auth . log, sys log, kern . log) en busca de actividades sospechosas.
- **Justificación:** La monitorización proactiva permite la detección temprana de intrusiones o actividades anómalas.

Disclaimer: Este informe se basa en los datos proporcionados. Las recomendaciones son genéricas y pueden necesitar ser adaptadas a la infraestructura específica del cliente y sus requisitos de negocio. Se recomienda realizar pruebas en un entorno no productivo antes de aplicar cambios críticos.